Mitigating Web Application Vulnerabilities

Internet and Web Application Security 3e - Lab 4

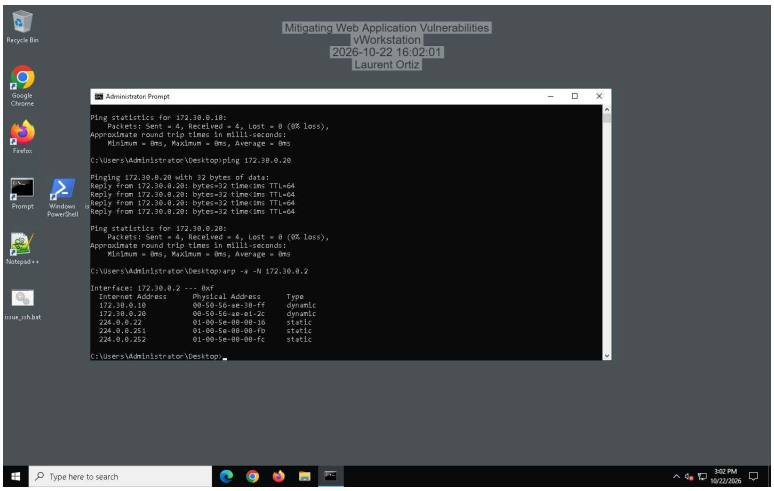
Student: Laurent Ortiz
Email: 10812531@uvu.edu
Report Generated: Thursday, October 22, 2026 at 7:50 PM

Time on Task: 2 hours, 0 minutes
Progress: 100%

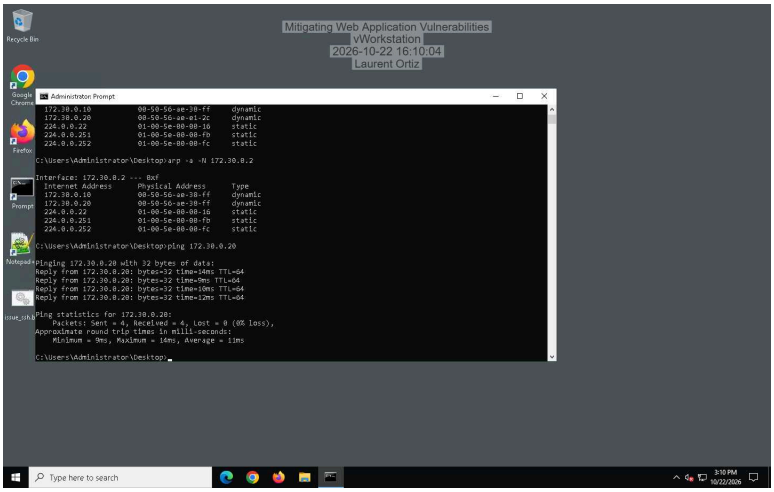
Section 1: Hands-On Demonstration

Part 1: Mitigate an HTTP MITM Attack by Using HTTPS

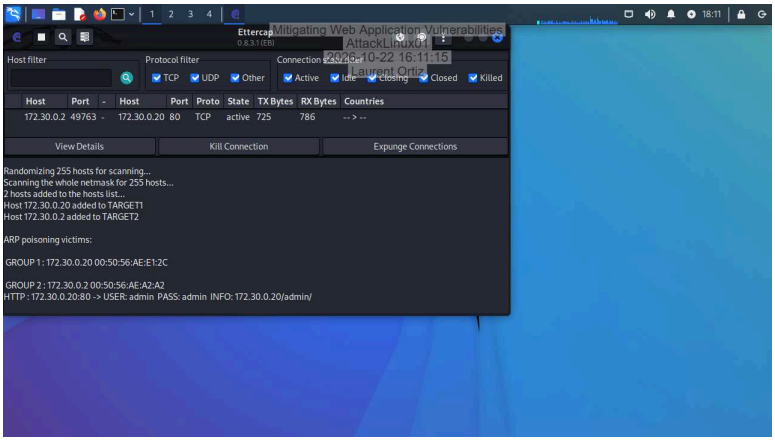
11. **Make a screen capture** showing the physical addresses for 172.30.0.10 and 172.30.0.20.



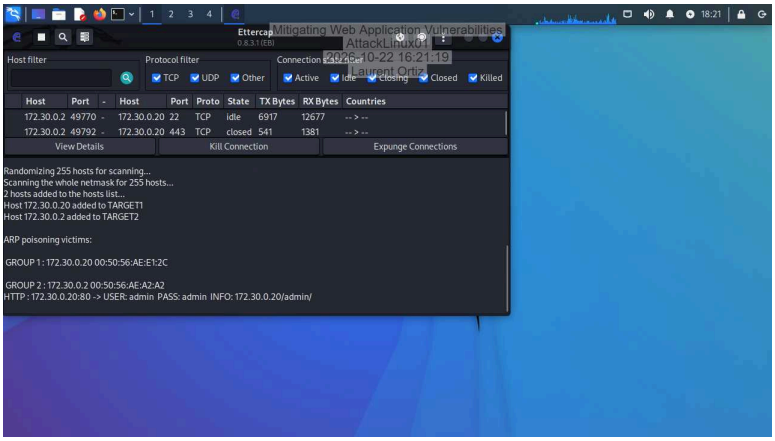
27. **Make a screen capture** showing the ARP information and the successful ping.



34. **Make a screen capture** showing the username and password in the Ettercap log.

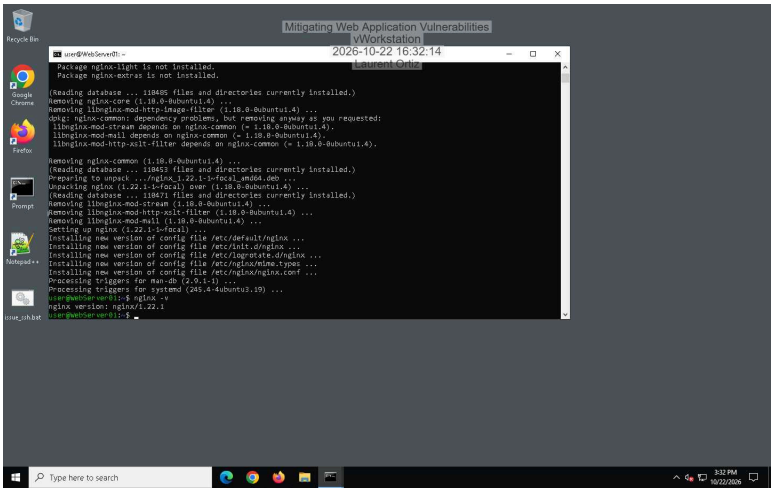


55. **Make a screen capture** showing the HTTPS connection in Ettercap.



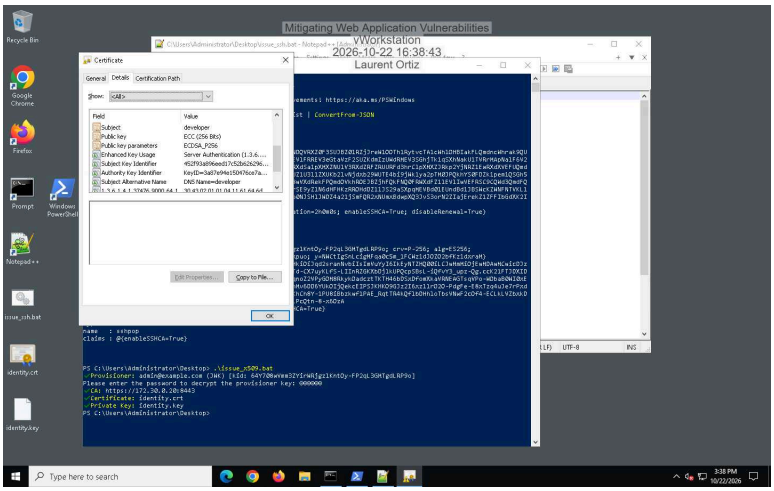
Part 2: Mitigate Potential Future Attacks by Updating the Web Server

10. **Make a screen capture** showing the new nginx version.

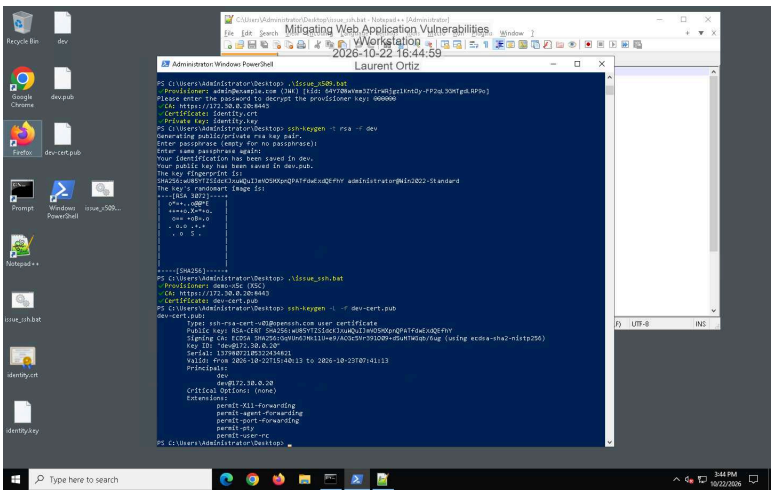


Part 3: Mitigate Unauthorized Changes Using Access Control

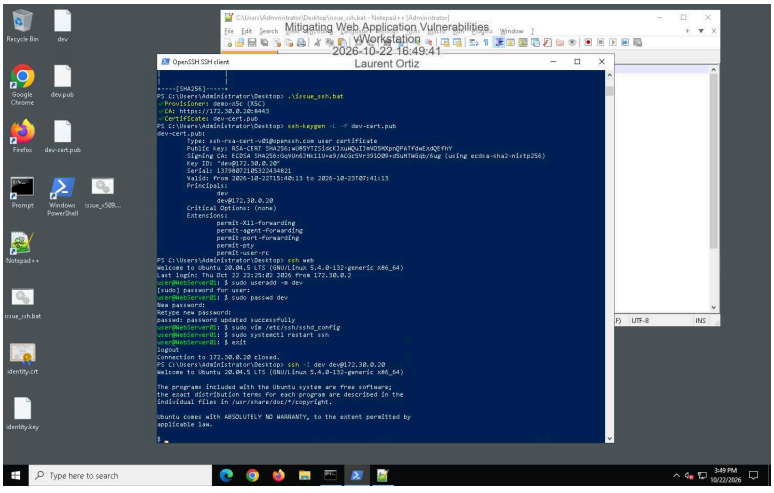
8. **Make a screen capture** showing the details of the certificate, including the Subject. You may have to enlarge the window to do this.



14. **Make a screen capture** showing the details of the SSH certificate.



27. **Make a screen capture** showing the successful login command and prompt on WebServer01.



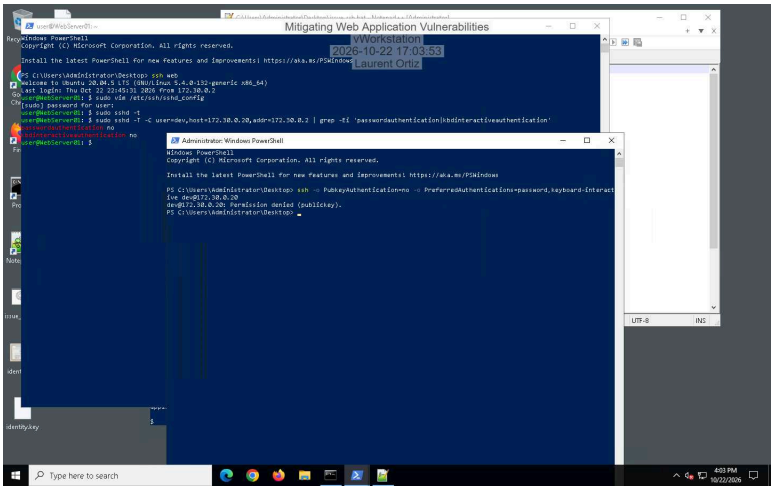
Section 2: Challenge and Analysis

Part 1: Disable Password Access for Dev

1. **Document the changes** required in the sshd_config file.

I modified the **/etc/ssh/sshd_config** file to disable password authentication for the dev account using the Match User dev directive with *PasswordAuthentication no* and *KbdInteractiveAuthentication no*. I verified the SSH configuration and tested an attempted login without a key or certificate on another terminal. The server rejected the connection with Permission denied (publickey), verifying that password-based authentication was disabled for the dev account.

2. **Make a screen capture** showing a rejected login when no key or certificate is used.



Part 2: Disable User-Supplied Authorized_keys for Dev

1. **Document the changes** required in the sshd_config file.

I've updated the **/etc/ssh/sshd_config** file by adding *AuthorizedKeysFile none* under the Match User dev directive. This prevents the SSH server from accepting ordinary public keys stored in the dev account's authorized_keys file. I generated a separate SSH key pair and tested the authentication using the private key without an SSH certificate. The server rejected the connection with Permission denied (publickey), displaying that key-only authentication was blocked.

2. **Make a screen capture** showing a rejected login when no certificate is used.

